

Phishing Risk Simulation

Prepared for:

Security Awareness Program Stakeholders

Prepared by:

Ashley D. Preyar

Cybersecurity Professional

MA, IO Psychology | CompTIA Security+

Date:

July 13, 2026

Executive Summary

Introduction

This report covers the outcomes of a phishing susceptibility simulation conducted for 12 weeks across 100 employees of a simulated organization. This project demonstrates the application of behavioral science principles to cybersecurity human risk modeling.

Objective

The goal of this simulation was to model how individual personality traits, stress levels, and phishing email characteristics influence employee click-through behavior, and to evaluate how security awareness training affects susceptibility over time.

Methodology

An agent-based model was built in Python with AI assistance. Each of the 100 simulated employees was assigned personality/behavioral traits - conscientiousness and risk-tolerance. Simulated employees were also given fluctuating stress levels influenced by phishing email urgency and authority characteristics. In addition, three email types (generic, urgent and authority-based) were issued across 12 weeks and training was only triggered when an employee clicked on a phishing email. Lastly, a SOC detection layer was simulated to operate independently of the behavioral model. These variables were chosen as an attempt to closely match a real-world environment.

Development note: This project was built using AI tools, which suggested the model variables and wrote the Python implementation. The author ran the simulation, reviewed the outputs, evaluated the assumptions using I-O psychology knowledge, and wrote the findings and recommendations.

Findings

Over the course of the 12 weeks, phishing clicks ranged from 28 to 41 out of 100 employees. The clicks peaked during urgent and authority-based (boss request) email weeks. Employees with low conscientiousness and high risk tolerance clicked more often than those with high conscientiousness and low risk tolerance. Awareness decay between training events resulted in increased click rates during Weeks 9 and 11 despite an overall downward trend. (See Table 1 & 2 below).

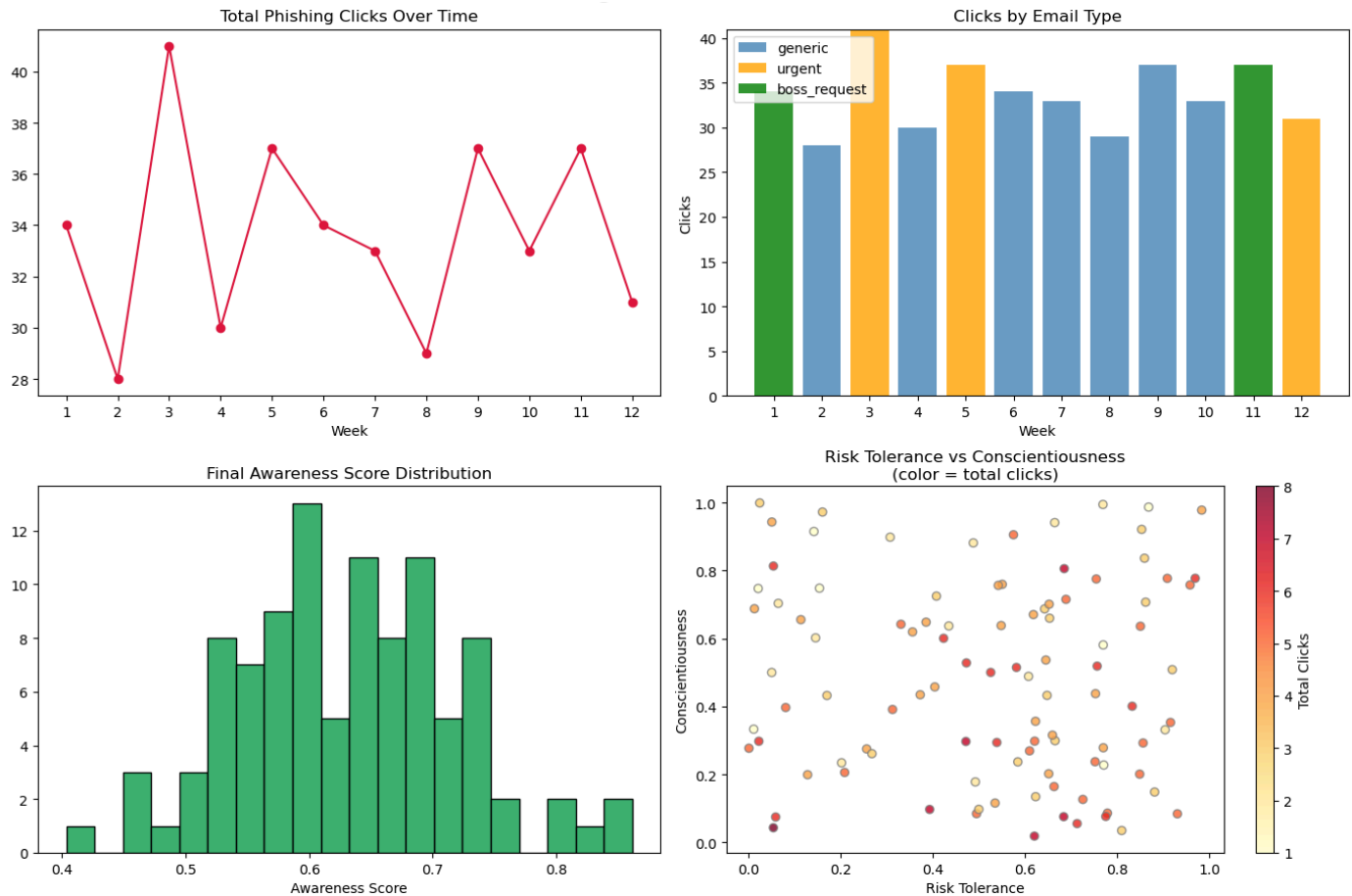
Limitations

The results reflect the assumptions built into the model and use simulated data; therefore, they should be read as an illustration of how these factors *could* interact, not as evidence about real-world employee behavior.

Table 1: Sample Run Data

Week	Email Type	Clicks	SOC Detected	High-Risk	Low-Conscie ntious
1	boss_request	34	22	10	17
2	generic	28	10	10	15
3	urgent	41	28	14	19
4	generic	30	14	9	11
5	urgent	37	26	16	15
6	generic	34	11	5	17
7	generic	33	16	9	14
8	generic	29	13	10	10
9	generic	37	12	9	14
10	generic	33	19	9	10
11	boss_request	37	23	11	19
12	urgent	31	18	10	11

Table 2: Phishing Simulation Results



Recommendations

- Awareness training should be prioritized for those with high risk-tolerance and low conscientiousness behavioral traits. Employees with these traits tended to click on phishing emails more.
- To reduce awareness decay, training frequency should be increased instead of depending upon one-off and sporadic programs. More exposure to security awareness information tends to boost one's likelihood of not clicking on phishing emails.
- Controls regarding authority-based and urgent emails should be implemented. These types of emails tended to influence the most clicks. Possible controls can include using DMARC to help prevent email spoofing. Also, simply establishing inside rules (e.g., urgent requests are to not be sent via email; always verify via a secondary mode of communication such as text/call/in-person) can help employees to think twice before clicking.

- Incorporate personality/behavior based segmentation into current security awareness training programs in order to account for employee differences - instead of using cookie cutter methods.
- Conduct assessments (e.g., behavioral, level of security awareness) to customize and segment training. Establish baselines to accurately measure and compare changes over time. This will help with determining how well security awareness training is performing and signal areas of improvement.

Conclusion

This simulation illustrates how personality, stress, and authority cues *could* combine to influence phishing click behavior within a model, showing that susceptibility may depend on factors beyond technical controls alone. Since the results come from simulated data and built-in assumptions, they are best used to frame questions and guide training design, not to draw conclusions about real employees. The project highlights the value of applying Industrial-Organizational (IO) psychology concepts to cybersecurity human risk and security awareness programs, and a logical next step would be validating these assumptions against real phishing exercise data.